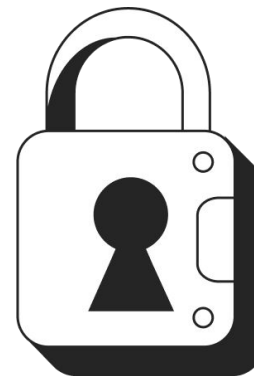
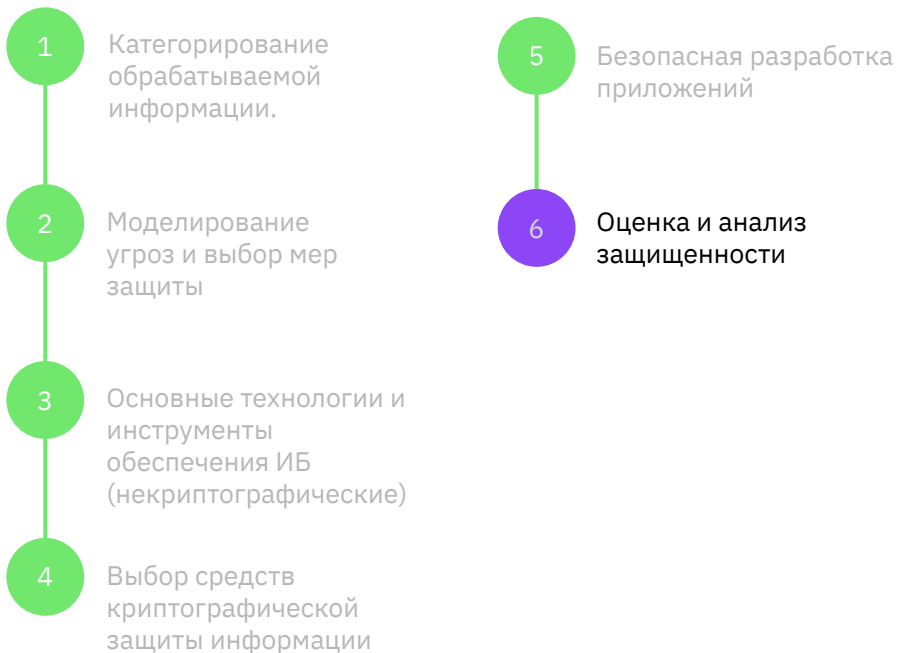


Основы информационной безопасности

Семинар 6. Оценка и анализ защищенности



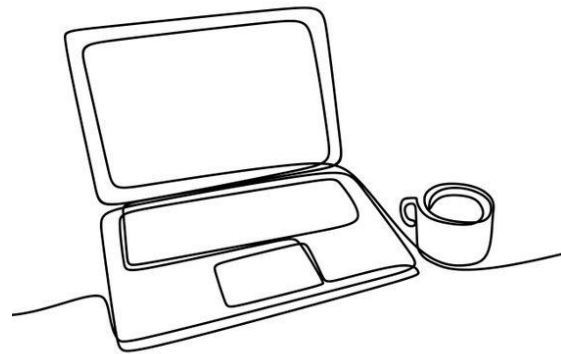
План семинаров “Основы информационной безопасности”





Что будет на уроке сегодня

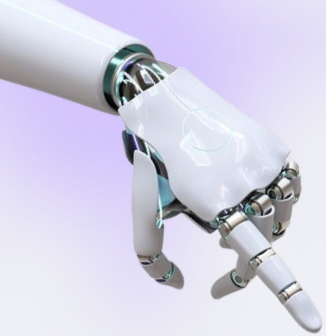
-  Повторение теории.
-  Задание №1 «Google hacking».
-  Задание №2 «The harvester».
-  Задание №3-4 «Nmap».
-  Задание №5 «Hydra».
-  Задание №6 «Online SAST».
-  Домашнее задание.
-  Подведение итогов.
-  Рефлексия (самоанализ).





Повторение теории





Вопрос

Отправные точки для OSINT?



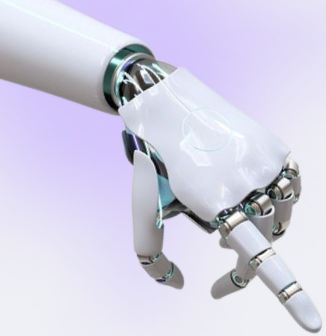


Ответ

Отправные точки для OSINT?

- 📌 Наименование организации.
- 📌 Имя человека/никнейм, логин в социальных сетях.
- 📌 Адрес электронной почты, номер телефона.
- 📌 Наименование/дата события (мероприятия).





Вопрос

**Какие варианты выявления
известных уязвимостей существуют?**



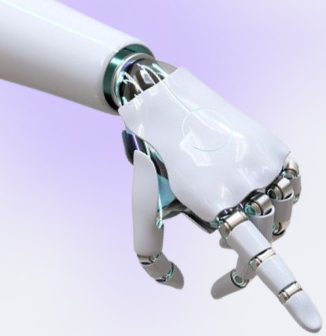


Ответ

Варианты выявления известных уязвимостей?

- 📌 Идентификация наименований и версий программного обеспечения, поиск в базах данных известных для них уязвимостей.
- 📌 Применение сканеров безопасности (например, Nessus, OpenVAS, XSpider, MaxPatrol VM, RedCheck и др.).
- 📌 Запуск тест-программ (эксплойтов), воспроизводящих в полном объёме или частично выполнение кибератак с использованием известных уязвимостей.





Вопрос

**Какие есть методы анализа
защищенности отдельных приложений?**





Ответ

Методы анализа защищенности отдельных приложений?

- 📌 Анализ (инспекция) кода (code review).
- 📌 Статический анализ (static application security testing (SAST)).
- 📌 Динамический анализ (dynamic application security testing (DAST)).
- 📌 Компонентный анализ (software composition analysis (SCA)).
- 📌 Анализ внешних зависимостей (open source analysis (OSA)).
- 📌 Фаззинг-тестирование ПО (fuzz testing).





Задания





Задание №1 «Google hacking»

Вам нужно проверить не опубликованы ли излишние документы на веб-сайте:

-  Банк данных угроз безопасности информации: bdu.fstec.ru
-  Образовательный портал: gb.ru
-  Любой другой веб-ресурс

Сравнить результаты поиска в различных поисковых системах:



10 минут



* Язык поисковых запросов Яндекс и Google:

https://www.seowizard.ru/blog/article/yazyk-poiskovyh-zaprosov-operator-yandex-i-google/#Operator_rhost



Задание №1 (ответ*)

Yandex search results for the query `site:bdu.fstec.ru mine:pdf`. The search bar shows the query and a close button. Below the search bar are tabs for 'поиск', 'картинки', 'видео', 'карты', 'товары', 'переводчик', and 'все'. The results are listed below:

- БДУ - Уязвимости**
bdu.fstec.ru > Уязвимости > 2023-07318
Описание уязвимости. Уязвимость компонента Adobe PDF браузера Microsoft Edge связана с выходом операции за границы буфера в памяти. Читать ещё
Не найдено: mine
- БДУ - Уязвимости**
bdu.fstec.ru > vul/2023-07840
<https://vuldb.com/ru/?id.244948> <https://www.postgresql.org/support/security/CVE-2023-5869/> <https://safe-surfl.ru/upload/VULN-new/VULN.2023-11-10.1.pdf> <https://...> Читать ещё
Не найдено: mine
- Обозначения и сокращения**
bdu.fstec.ru > files/documents/scanovallforlinux_...
1. ПРОГРАММА, ИСПОЛЬЗУЮЩАЯ ОПИСАНИЯ УЯЗВИМОСТЕЙ НА ЯЗЫКЕ OVAL ДЛЯ АВТОМАТИЗИРОВАННЫХ ПРОВЕРОК НАЛИЧИЯ УЯЗВИМОСТЕЙ... Читать ещё
Не найдено: mine

At the bottom of the third result, there is a red PDF icon and a button labeled 'Посмотреть'.

Google search results for the query `site:bdu.fstec.ru filetype:pdf`. The search bar shows the query and a close button. Below the search bar are tabs for 'Все', 'Книги', 'Картинки', 'Покупки', 'Видео', 'Ещё', and 'Инструменты'. The results are listed below:

Результатов: примерно 4 (0,12 сек.)

- fstec.ru**
https://bdu.fstec.ru/files/documents/scanovallforlinux_...
программа, использующая описания уязвимостей на ...
Обозначения и сокращения 3. 1 Назначение программы .
17 страниц
- fstec.ru**
https://bdu.fstec.ru/scanovallforlinux_alse_manual_...
программа, использующая описания уязвимостей на ...
2. СОДЕРЖАНИЕ. Обозначения и сокращения 3. 1 Назначение программы .
18 страниц
- fstec.ru**
https://bdu.fstec.ru/documents/scanovall_manual_...
Программа, использующая описания уязвимостей на язык
В разделе «Назначение программы» данного документа, приведены сведения о назначении программы и информация, необходимая для понимания функций.
13 страниц

* Возможны авторские варианты ответов

Задание №2 «The harvester».

Вам нужно собрать публично доступную информацию по домену*:

-  Банк данных угроз безопасности информации: bdu.fstec.ru
-  Образовательный портал: gb.ru
-  Любой другой веб-ресурс

```
(root@kali)-[~]
# theHarvester -h
*****
*
* [TheHarvester]
*
* theHarvester 4.4.4
* Coded by Christian Martorella
* Edge-Security Research
* cmartorella@edge-security.com
*
*****
usage: theHarvester [-h] -d DOMAIN [-l LIMIT] [-S START] [-p] [-s] [--screenshot SCREENSHOT]
                  [-v] [-e DNS_SERVER] [-t] [-r [DNS_RESOLVE]] [-n] [-c] [-f FILENAME]
                  [-b SOURCE]

theHarvester is used to gather open source intelligence (OSINT) on a company or domain.

options:
  -h, --help            show this help message and exit
```

10 минут



* Описание: <https://www.kali.org/tools/theharvester/>



Задание №2 (ответ*)

```

└─# theHarvester -d bdu.fstec.ru -b all -f fstec_harvester_info
*****
*
*
*
*
*
*
*
*
* theHarvester 4.4.4
* theHarvester 4.4.4 Coded by Christian Martorella
* Coded by Christian Martorella
* Edge-Security Research
* cmartorella@edge-security.com
*
*
*****
[!] Target: gb.ru
[*] Target: bdu.fstec.ru

```

```
▼ object {1}
  ▼ theHarvester {2}
    email : webmaster@bdu.fstec.ru
    ▼ host [3]
      0 : www.bdu.fstec.ru
      1 : www.bdu.fstec.ru
      2 : www.bdu.fstec.ru
```

* Возможны авторские варианты ответов

Задание №2 (ответ*)

[illegible]

```
▼ object {1}
  ▼ theHarvester {1}
    ▼ host [5138]
      0 : *.gb.ru
      1 : gb-auth-feature-1.dev.gb.ru
      2 : wazuh-dashbord01.admin.gb.ru
      3 : staging20.staging.gb.ru
      4 : orders.gb.ru
      5 : predprod.gb.ru
      6 : gb-auth-branch.dev.gb.ru
      7 : o.gb.ru
      8 : api.test-stand.gb.ru
      9 : ns2.gb.ru
      10 : staging14.staging.gb.ru
      11 : staging11.staging.gb.ru
      12 : a2leader360.gb.ru
```

* Возможны авторские варианты ответов



Задание №3 «Nmap»



Вам нужно просканировать доступный(ые) хост(ы)*

```
(root@kali)-[~]  
# nmap -h  
Nmap 7.93 ( https://nmap.org )  
Usage: nmap [Scan Type(s)] [Options] {target specification}
```

```
(root@kali)-[~]  
# nmap -sn 127.0.0.1
```

Zenmap

Сканирование Инструменты Профиль Помощь

Цель 127.0.0.1 Профиль Сканирование

Команда nmap -sn 127.0.0.1

15 минут



* Описание: <https://www.kali.org/tools/nmap/>
Параметры сканирования: <https://kali.tools/?p=1317>



Задание №3 (ответ*)

```
(root@kali)~[~]
# nmap -sn 127.0.0.1
Starting Nmap 7.93 ( https://nmap.org ) at 2023-11-27 10:49 MSK
Nmap scan report for localhost (127.0.0.1)
Host is up.
Nmap done: 1 IP address (1 host up) scanned in 0.00 seconds

(root@kali)~[~]
# nmap -sO 127.0.0.1
Starting Nmap 7.93 ( https://nmap.org ) at 2023-11-27 10:50 MSK
Nmap scan report for localhost (127.0.0.1)
Host is up (0.0000030s latency).
Not shown: 249 closed n/a protocols (proto-unreach)

```

PROTOCOL	STATE	SERVICE
1	open	icmp
2	open filtered	igmp
6	open	tcp
17	open	udp
103	open filtered	pim
136	open filtered	udplite
255	open filtered	unknown

```
Nmap done: 1 IP address (1 host up) scanned in 1.29 seconds

(root@kali)~[~]
# nmap --reason 127.0.0.1
Starting Nmap 7.93 ( https://nmap.org ) at 2023-11-27 10:51 MSK
Nmap scan report for localhost (127.0.0.1)
Host is up, received localhost-response (0.0000030s latency).
All 1000 scanned ports on localhost (127.0.0.1) are in ignored states.
Not shown: 1000 closed tcp ports (reset)
Nmap done: 1 IP address (1 host up) scanned in 0.12 seconds
```

The Zenmap interface shows the following scan results:

Scan 1: nmap -sn 127.0.0.1

Starting Nmap 7.92 (https://nmap.org) at 2023-11-27 10:48 RTZ 2 (ceia)
Nmap scan report for localhost (127.0.0.1)
Host is up.
Nmap done: 1 IP address (1 host up) scanned in 0.23 seconds

Scan 2: nmap -sO 127.0.0.1

Starting Nmap 7.92 (https://nmap.org) at 2023-11-27 10:47 RTZ 2 (ceia)
Nmap scan report for localhost (127.0.0.1)
Host is up (0.00038s latency).
Not shown: 249 closed n/a protocols (proto-unreach)

PROTOCOL	STATE	SERVICE
1	open	icmp
2	open filtered	igmp
6	open	tcp
17	open	udp
50	open filtered	esp
51	open filtered	ah
58	open filtered	ipv6-icmp

Nmap done: 1 IP address (1 host up) scanned in 2.63 seconds

Scan 3: nmap --reason 127.0.0.1

Starting Nmap 7.92 (https://nmap.org) at 2023-11-27 10:42 RTZ 2 (ceia)
Nmap scan report for localhost (127.0.0.1)
Host is up, received localhost-response (0.00020s latency).
Not shown: 997 closed tcp ports (reset)

PORT	STATE	SERVICE	REASON
135/tcp	open	msrpc	syn-ack ttl 128
445/tcp	open	microsoft-ds	syn-ack ttl 128
6129/tcp	open	unknown	syn-ack ttl 128

Nmap done: 1 IP address (1 host up) scanned in 0.44 seconds

* Возможны авторские варианты ответов



Задание №4 «Nmap»

Вам нужно проверить доступный(ые) хост(ы) на уязвимости*:

- 📌 Банк данных угроз безопасности информации: bdu.fstec.ru
- 📌 Образовательный портал: gb.ru
- 📌 Любой другой хост

```
(root@kali)-[/usr/share/nmap/scripts]  
# nmap --script vuln 10.1
```

```
(root@kali)-[/usr/share/nmap/scripts]  
# nmap --script vulners 10.1
```

10 минут



* Описание: <https://www.kali.org/tools/hydra/>



Задание №4 (ответ*)

```
(root@kali)-[~]  
# nmap --script vuln gb.ru  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2023-11-27 16:03 MSK  
Nmap scan report for gb.ru (178.248.232.209)  
Host is up (0.0031s latency).  
Not shown: 998 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
80/tcp    open  http
```

```
|_http-dombased-xss: Couldn't  
|_http-stored-xss: Couldn't  
|_http-csrf: Couldn't find  
|_http-aspnet-debug: ERROR  
|_http-vuln-cve2014-3704:  
443/tcp   open  https  
|_http-vuln-cve2014-3704:  
|_http-dombased-xss: Couldn't  
|_http-csrf: Couldn't find  
|_http-stored-xss: Couldn't
```

```
Nmap done: 1 IP address (1 host up) scanned in 2.55.09 seconds
```

```
(root@kali)-[~]  
# nmap --script vulners gb.ru  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2023-11-27 16:03 MSK  
Nmap scan report for gb.ru (178.248.232.209)  
Host is up (0.0029s latency).  
Not shown: 998 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
80/tcp    open  http  
443/tcp   open  https  
  
Nmap done: 1 IP address (1 host up) scanned in 4.86 seconds
```



Задание №4 (ответ*)

```
(root@kali)-[~]
# nmap --script vuln bdu.fstec.ru
Starting Nmap 7.94SVN ( https://nmap.org ) at 2023-11-27 15:58 MSK
Pre-scan script results:
| broadcast-avahi-dos:
|   Discovered hosts:
|     224.0.0.251
|   After NULL UDP avahi packet DoS (CVE-2011-1002).
|_  Hosts are all up (not vulnerable).
Nmap scan report for bdu.fstec.ru (95.173.157.16)
Host is up (0.034s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-vuln-cve2014-3704: ERROR: Script execution failed
|_http-stored-xss: Couldn't find any stored XSS vulnera
|_http-aspnet-debug: ERROR: Script execution failed (us
|_http-csrf: Couldn't find any CSRF vulnerabilities.
443/tcp   open  https
|_http-aspnet-debug: ERROR: Script execution failed (us
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-stored-xss: Couldn't find any stored XSS vulnera
8080/tcp  open  http-proxy
|_http-aspnet-debug: ERROR: Script execution failed (us
|_http-vuln-cve2014-3704: ERROR: Script execution failed
Nmap done: 1 IP address (1 host up) scanned in 197.41 s
```

```
(root@kali)-[~]
# nmap --script vulners bdu.fstec.ru
Starting Nmap 7.94SVN ( https://nmap.org ) at 2023-11-27 16:09 MSK
Nmap scan report for bdu.fstec.ru (95.173.157.16)
Host is up (0.030s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https
8080/tcp  open  http-proxy
Nmap done: 1 IP address (1 host up) scanned in 14.63 seconds
```



Задание №4 (ответ*)

```
(root@kali)-[/usr/share/nmap/scripts]
# nmap --script vuln 10.1
Starting Nmap 7.93 ( https://nmap.org ) at 2023-11-27 14:31 MSK
Nmap scan report for 10.1
Host is up (0.000054s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
111/tcp   open  rpcbind
2049/tcp  open  nfs
MAC Address: 00:0C:29:5B:E1:C1 (VMware)
```

```
(root@kali)-[/usr/share/nmap/scripts]
# nmap --script vuln 10.1
Starting Nmap 7.93 ( https://nmap.org ) at 2023-11-27 14:31 MSK
Nmap scan report for 10.1
Host is up (0.00016s latency).
Not shown: 992 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-passwd: ERROR: Script execution failed (use -d to debug)
|_http-vuln-cve2013-7091: ERROR: Script execution failed (use -d to debug)
|_http-dombased-xss: Couldn't find any DOM based XSS.
139/tcp   open  netbios-ssn
Host script results:
|_smb-vuln-ms10-054: false
|_smb-vuln-regsvcs-dos:
|   VULNERABLE:
|     Service regsvcs in Microsoft Windows systems vulnerable to denial of service
|     State: VULNERABLE
|     The service regsvcs in Microsoft Windows 2000 systems is vulnerable to denial of service
|     caused by a null deference
|     pointer. This script will crash the service if it is vulnerable. This vulnerability was
|     discovered by Ron Bowes
|     while working on smb-enum-sessions.
|_
|_smb-vuln-ms10-061: false
Nmap done: 1 IP address (1 host up) scanned in 94.16 seconds
```

* Возможны авторские варианты ответов



Задание №5 «Hydra»

📌 Вам нужно проверить доступный(ые) хост(ы) на использование популярных (слабых) паролей*

```
(root@kali)-[/]
# hydra -h
Hydra v9.4 (c) 2022 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Syntax: hydra [[[-l LOGIN|-L FILE] [-p PASS|-P FILE]] | [-C FILE]] [-e nsr] [-o FILE] [-t TASKS] [-M FILE [-T TASKS]] [-w TIME] [-W TIME] [-f] [-s PORT] [-x MIN:MAX:CHARSET] [-c TIME] [-ISOuvVd46] [-m MODULE_OPT] [service://server[:PORT][/OPT]]
```



10 минут

* Описание: <https://www.kali.org/tools/hydra/>



Задание №5 (ответ*)

```
(root@kali)-[/]
# nmap --reason 10.1...
Starting Nmap 7.93 ( https://nmap.org ) at 2023-11-27 11:59 MSK
Nmap scan report for 10.1...
Host is up, received arp-response (0.000055s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE REASON
21/tcp    open  ftp     syn-ack ttl 64
22/tcp    open  ssh     syn-ack ttl 64
111/tcp   open  rpcbind syn-ack ttl 64
2049/tcp  open  nfs     syn-ack ttl 64
MAC Address: 00:0C:29:5B:E1:C1 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 16.69 seconds

(root@kali)-[/]
# hydra -s 22 -l root -P /usr/share/john/password.lst 10.1... -t 4 ssh
Hydra v9.4 (c) 2022 by van Hauser/THC & David Maciejak - Please do not use in military or secret servi
ce organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anywa
y).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2023-11-27 12:01:05
[DATA] max 4 tasks per 1 server, overall 4 tasks, 3561 login tries (l:1/p:3561), ~891 tries per task
[DATA] attacking ssh://10.1...:22/
[22][ssh] host: 10.1... login: root password: ...
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2023-11-27 12:01:05
```

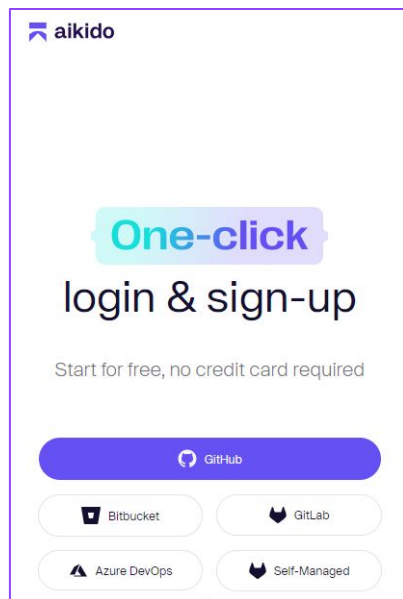
```
(root@kali)-[/]
# hydra -s 22 -l root -P /usr/share/john/password1.lst 10.1... -t 4 ssh
Hydra v9.4 (c) 2022 by van Hauser/THC & David Maciejak - Please do not use in military or secret servi
ce organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anywa
y).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2023-11-27 13:03:44
[WARNING] Restorefile (you have 10 seconds to abort ... (use option -I to skip waiting)) from a previou
s session found, to prevent overwriting, ./hydra.restore
[DATA] max 4 tasks per 1 server, overall 4 tasks, 20 login tries (l:1/p:20), ~5 tries per task
[DATA] attacking ssh://10.1...:22/
1 of 1 target completed, 0 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2023-11-27 13:04:10
```

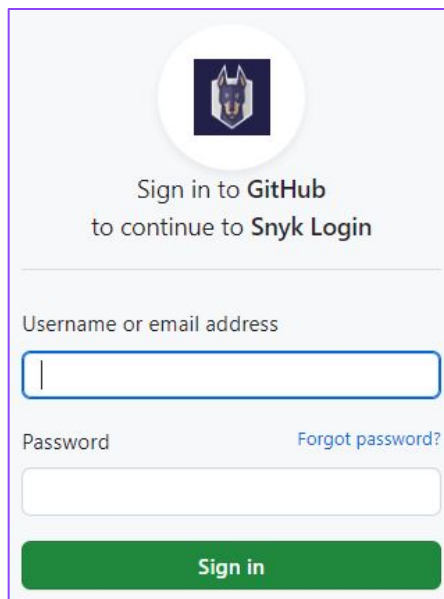


Задание №6 “Online SAST”

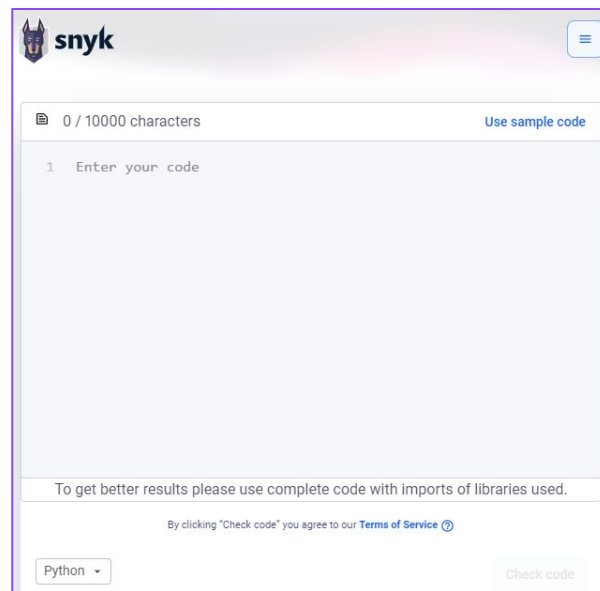
 Вам нужно проверить код на уязвимости с использованием SAST-инструментов*:



The Aikido login & sign-up page features the Aikido logo at the top left. Below it is a large blue button with the text "One-click login & sign-up". Underneath this button, it says "Start for free, no credit card required". At the bottom, there are five buttons for different authentication methods: GitHub, Bitbucket, GitLab, Azure DevOps, and Self-Managed.



The Snyk login page shows a GitHub logo in a circle at the top. Below it, the text reads "Sign in to GitHub to continue to Snyk Login". There are two input fields: "Username or email address" and "Password". A "Forgot password?" link is next to the password field. A green "Sign in" button is at the bottom.



The Snyk code checker page has a header with the Snyk logo and a menu icon. Below the header, there is a text area for entering code, with a character count "0 / 10000 characters" and a "Use sample code" link. A "1 Enter your code" prompt is at the top of the text area. At the bottom, there is a note about using complete code with imports, a "Terms of Service" link, a "Python" dropdown menu, and a "Check code" button.

* Описание: <https://app.aikido.dev/> и <https://snyk.io/code-checker/>



Задание №6 (ответ*)



Scanning View more ×

Scanning 2 repos for exposed secrets, infrastructure as code and surface monitoring.

Scanning View more ×

Scanning 2 repos for exposed secrets and surface monitoring.

Scan complete Refresh feed ×

Your scans have completed. You can now refresh the queue to view all new results.

Rep nam	Severity	Language	Open	Ignored	Last scan	:
	No risk		0	0	11 mi	
	No risk		0	0	11 mi	



We found 1 issues in your code

H 0 high severity
 M 1 medium severity
 L 0 low severity

M Code Injection

VULNERABILITY | [CWE-94](#)

```

2 compute_user_input = input('\nFactors and operator for computingte: ')
3 if not compute_user_input:
4     print ("No input")
5 else:
6     print ("Result: ", eval(compute_user_input))
  
```

Unsanitized input from user input flows into eval, where it is executed as Python code. This may result in a Code Injection vulnerability.

Targets 2

Search targets

>
0
0 C 0 H 0 M 0 L
...

>
0
0 C 0 H 0 M 0 L
...

* Возможны авторские варианты ответов



Домашнее задание



Домашнее задание



Напишите программу на Python, которая будет проводить сканирование с использованием nmap



Результат: файл формата .py или .ipynb.





Вопросы?

Вопросы?



Вопросы?





Подведем итоги



Что было
сложного на
семинаре?





Напишите 3 вещи в
комментариях, которым
вы научились сегодня.





Как настроение?





Спасибо за работу!